Lab 6 – Secure Testing using SAST Tool

You have developed a web-based student portal for a university (In Lab 5). The portal allows students to:

- Log in to view grades and attendance
- Submit assignments
- Communicate with lecturers via messaging
- Update personal information

Continue: Scenario

Excellent work. Your student portal application is now successfully developed and running. The next step is to test the application using a SAST tool. In this activity, you will scan the source code to look for possible security weaknesses, review the findings, and understand how SAST helps developers detect security issues early before deployment.

Step 1 — Confirm the secured application is working properly

Before scanning, verify:

- login works with valid credentials
- wrong login returns generic error
- assignment upload accepts allowed file types
- messaging works
- profile update only edits the logged-in user profile

This is important because SAST scans code, but DAST later needs a working live app.

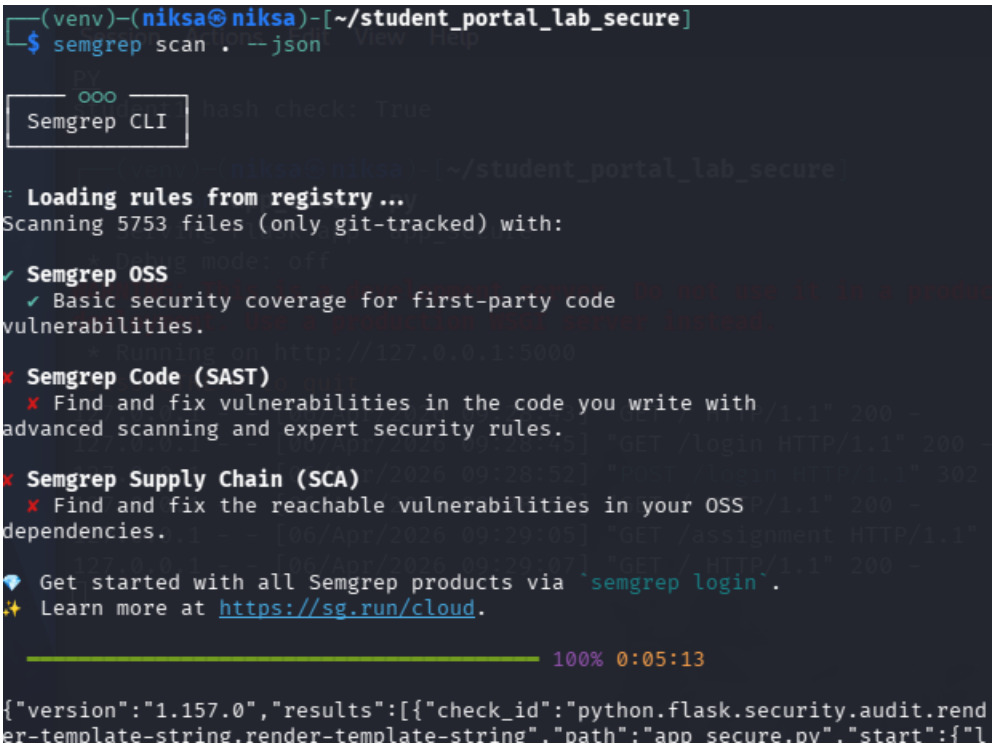
Step 2 — Install Semgrep for SAST

Make sure your venv active (if you use env when setup):

- *pip install semgrep*

Run a scan in the project folder:

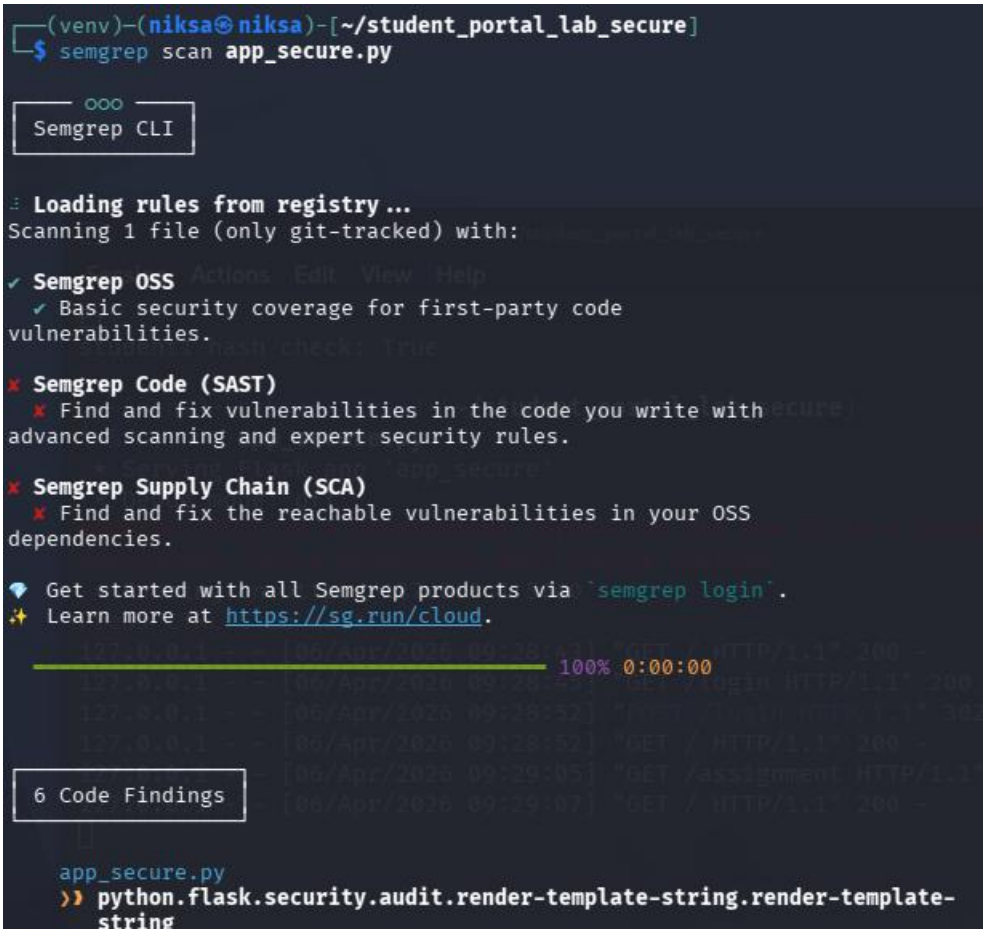
semgrep scan .



OR

scan only the app file:

semgrep scan app_secure.py



This checks the source code for insecure patterns.

Example: *semgrep scan --config auto . --json -o semgrep-results.json*

It build the summary from:

- total findings
- findings by severity
- affected files
- most important rule IDs
- short remediation focus

Your Task:

1- Create a proper detail report from this *semgrep* tool. (Example; View and export the report details nicely in a file using JSON, etc.)
2- Fill up the form attached with report detail and submit to Moodle.